Towards a Field-Informed Risk-Based Framework for PQC Migration in Legacy Systems

Paul CHAMMAS[1 2], Khalil HARISS[1], Carole BASSIL[3], Maroun CHAMOUN[1]

[1] Saint-Joseph University, www.usj.edu.lb
[2] Quantum Risk Advisory (QuRISK), www.qurisk.fr
[3] Paths Of Technology (P.O.Tech), www.potech.global
June 2025

Abstract

Ongoing advances in quantum computing represent a growing risk to modern cryptography (potentially threatening both asymmetric and symmetric encryption protocols), thereby challenging the foundations of digital security. In response, global cybersecurity communities, led by standardization bodies such as NIST and ETSI, launched initiatives to establish migration pathways toward post-quantum cryptography (PQC).

However, the migration of legacy systems to quantum-safe cryptography presents many challenges that have not yet been addressed due to their limited cryptographic agility, outdated infrastructure, and regulatory constraints. These legacy environments, even though they rely on aging technologies and constrained hardware, are still vital to major sectors (such as finance, energy, healthcare, and government).

This paper explores some obstacles to the implementation of PQC in these environments, such as hard-coded cryptographic functions, outdated programming languages, hardware limitations, vendor lock-in, interoperability constraints, and certification issues. This shows that, in contrast to contemporary systems, legacy systems cannot be readily modified or easily re-engineered.

A critical review of existing standards and academic publications revealed key limitations: their focus on algorithms specifications, the abstract guidance provided without operational depth, the lack of empirical validations, and the insufficient risk modeling and attention to legacy constraints. These gaps prevent effective planning and secure execution of the PQC migration in legacy systems.

Consequently, this position paper argues that existing deliverables remain insufficient to address the specific challenges of PQC migration in legacy systems. It proposes the elaboration of a field-informed risk-based framework for PQC Migration in Legacy Systems to guide this transition. This proposed framework combines three interdepedent layers: a diagnostic characterization of legacy system constraints, a qualitative risk assessment grounded in those constraints, and a quantitative evaluation of migration options through an ROI-based analysis to support decision-making. Unlike existing approaches that treat legacy as generic labels, this framework begins by exploring what makes each system legacy in its specific context before applying the risk model. Its development is informed by an empirical survey conducted among large organizations across critical sectors, ensuring relevance beyond theoretical assumptions.

Future work will focus on elaborating the framework through applied research, tool development, and real-world case studies in collaboration with financial institutions and critical infrastructure operators. In addition, continued engagement with cyber authorities and standardization bodies will help us ensure alignment with emerging regulations.

Contact: `paul@qurisk.fr`

1 Introduction

The rise of the quantum cyber threat is a direct consequence of the rapid advances of quantum computing. Since public and private actors are heavily invested in the development of increasingly powerful quantum computers [1], a growing consensus is forming around the fact that these machines, once sufficiently mature, could break a large portion of the asymmetric encryption protocols currently in use and even threaten certain weaker symmetric protocols [2]. This threat arises because asymmetric schemes like RSA [3], DSA [4], ElGamal [5], and ECC [6], rely on difficult mathematical problems such as integer factorization and discrete logarithms, which can be efficiently solved by Shor's algorithm [7] on a sufficiently powerful quantum computer. Despite the fact that symmetric encryptions are comparatively more resistant, they are not immune to quantum attacks: Grover's algorithm [8] enables a quadratic speedup in brute-force key searches, effectively reducing the security levels of symmetric schemes such as AES [9] by half (for example, AES-256 would provide only ~ 128 bit security against quantum attacks).

Moreover, the field of quantum computing is witnessing continuous breakthroughs [10], both in hardware and algorithmic optimization, which may accelerate the timeline of the anticipated threat, initially projected between 5 to 10 years [11]. These risks are already being taken very seriously by the main cybersecurity authorities around the world, such as NIST (United States) [12], ANSSI (France) [13], BSI (Germany) [14], and NIS Cooperation Group (Europe) [15], all of which advocate for immediate anticipation of these threats.

One of the most feared attacks is known as 'Harvest Now, Decrypt Later' [16], which involves intercepting and storing data encrypted with classical algorithms today, in anticipation of having quantum computing power in the future to decrypt them. This scenario makes migration to post-quantum cryptography (PQC) all the more urgent today in order to protect long-term communications, sensitive data, and critical infrastructures. Therefore, several international initiatives (most notably the NIST PQC Standardization Program [12]) are working to select robust PQC protocols and gradually publishing migration guidelines to help organizations plan this transition [17].

Despite these efforts, many challenges remain with respect to PQC migration. These include uncertainties regarding the precise timeline of the quantum threat, doubts surrounding the maturity and resilience of proposed PQC protocols, and the technical and operational complexities of hybrid implementations [18]. However, a particularly critical and underexplored challenge lies in the difficulty of migrating legacy systems, especially within large and complex IT infrastructures [19].

Legacy environments [20] represent a fundamental aspect of the IT and operational infrastructure of many public and private organizations. These systems (exemplified in Table 1), though often based on decades-old technologies, continue to support mission-critical functions in sectors such as banking, healthcare, energy, transportation and government [21]. Their longevity is explained by their stability, deep integration into business processes, and the high cost or risk of replacement [22].

Legacy Systems	**Description**
Legacy IT Systems in Critical Sectors	Key sectors like banking, healthcare, energy, and government, still rely on decades-old legacy systems that lack modern security, are hard to integrate, and resist adaptation to current or future changes like PQC migration [23].
COBOL-Based Platforms	Numerous financial and administrative systems continue to operate on 1970s-era COBOL platforms, with challenging modernization required because of embedded logic and dependencies necessitating customized cryptographic updates [24].
Legacy ICS/SCADA Systems in Critical Infrastructure	Industrial Control Systems (ICS) and Supervisory Control and Data Acquisition (SCADA) platforms, common in industry and manufacturing, often rely on outdated technology, lack cryptographic support, and are difficult to properly secure [25].
Systems with Low Cryptographic Agility	Components like IoT devices [26], embedded systems, custom-built protocols, and appliances with hard-coded encryption may be secure classically but lack crypto-agility, making PQC adoption difficult. [27].

Table 1: Examples of Legacy Environments to be considered

This position paper calls for a comprehensive risk-based framework specifically designed for PQC migration in legacy environments [20]. This framework is meant to equip the stakeholders concerned (e.g. CISOs, IT managers, risk managers) with methodologies to assess migration readiness, evaluate and quantify risks, and define actionable and context-aware migration strategies. Closing the gap between cryptographic innovation and operational reality, this specialized approach is essential to ensure secure, compliant, and sustainable quantum resilience in legacy-dominated environments.

2 The Challenges of PQC Migration in Legacy Systems

Despite the fact that legacy systems remain essential to the continuity of many critical operations, their structural and operational constraints introduce significant barriers to post-quantum cryptographic transition. These environments present a variety of technical, organizational and regulatory challenges (as shown in Table 2) that must be carefully addressed to ensure a secure and feasible PQC migration [28].

Ref.	Challenges
2.1	Cryptographic Rigidity and Lack of Agility
2.2	Resource Constraints and Performance Limitations
2.3	Interoperability Issues and Vendor Dependencies
2.4	Regulatory and Certification Barriers
2.5	Operational Risks and System Fragility
2.6	Organizational Barriers and Structural Constraints
2.7	Programming Language Barriers

Table 2: Challenges of PQC Migration in Legacy Systems

2.1 Cryptographic Rigidity and Lack of Agility

One major challenge in legacy environments is their inherent lack of cryptographic agility [29]. Unlike modern systems, which are built with modularity in mind, legacy infrastructures often have deeply embedded cryptographic functions within their firmware. This leads to hard-coded algorithms, static key handling, and rigid protocol stacks that make it difficult to integrate new cryptographic primitives without substantial re-engineering [30]. Newly proposed PQC protocols, which feature different key sizes, distinctive signature formats, and computational requirements, cannot simply be plugged into these systems [31]. Retrofitting them usually requires extensive redevelopment, which introduces significant risks to system integrity and business continuity [32].

2.2 Resource Constraints and Performance Limitations

PQC protocols usually require more intensive resources than current classical encryptions [33]. Many legacy systems run on aged hardware, with limited CPU capacity and memory bandwidth, or lacking the required cryptographic acceleration needed to handle PQC operations efficiently. Lattice-based key encryption mechanisms (KEM) and hash-based signature schemes [34] can significantly increase the latency or the throughput requirements, which could be problematic for real-time systems or high-availability environments [35]. As a result, resource limitations not only jeopardize easy implementation, but may also require hardware enhancement, which may not be possible due to technical or financial considerations [22].

2.3 Interoperability Issues and Vendor Dependencies

Legacy infrastructures often include multiple components from different vendors, many of whom no longer support updates or lack PQC-compliant roadmaps [22]. In these environments, interoperability becomes an important issue [36]. A single cryptographic upgrade can trigger widespread incidents if not properly coordinated in related information systems [29]. Furthermore, legacy APIs and proprietary stacks often resist modification, creating vendor lock-in situations that prevent progress [32]. In the absence of active industry engagement and regulatory pressure, many vendors would likely delay PQC adoption, leaving organizations exposed to extended periods of vulnerability to quantum cyber threats [31].

2.4 Regulatory and Certification Barriers

Many legacy systems are present in highly regulated sectors (e.g., finance, healthcare, transportation) with critical infrastructure, in which any major change to cryptographic mechanisms can trigger compliance audits or recertifications [32]. PQC protocols, while progressing through standardization, are not yet well recognized in global certification frameworks (e.g., FIPS [37], Common Criteria [38], eIDAS [39]) [40]. Moreover, the shift towards hybrid PQC implementation adds legal ambiguity, requiring organizations to carefully balance the urgency of cryptographic upgrades with regulatory restrictions [41].

2.5 Operational Risks and System Fragility

Legacy systems are often considered mission critical and fragile, operating in environments where even minor modifications can result in cascading failures, unplanned downtime, or weak performance [42]. Cryptographic transitions are by nature systemic and sensitive, can introduce bugs, disrupt integrations, or alter authentication workflows [43]. In systems with poor documentation or in the absence of original developers, upgrades are prone to significant risks. The lack of structured planning, testing, rollback and contingency strategies, can expose organizations to greater harm from the migration effort than from quantum cyber threat [29].

2.6 Organizational Barriers and Structural Constraints

In addition to technical limitations, the migration of legacy systems to quantum safe protocols can be obstructed by budget limitations, undefined ownership of the system, or other organizational factors [42]. These systems were deployed sometimes decades ago under outdated structural and operational conditions, which may affect the required governance structure and stakeholder alignment needed to support this massive transformation. Also, these organizational challenges are closely tied to the maturity of internal processes such as IT asset management [44], lifecycle management [45], obsolescence management [46], and IT debt management [47]. The weaker these processes are, the more complex and risky the migration becomes, while robust, well-integrated practices in these areas can significantly ease the transition and mitigate associated risks [29].

2.7 Programming Language Barriers

Legacy systems sometimes depend on outdated programming languages such as COBOL, early versions of C, or even assembly. These languages do not naturally support modern security features such as strong encryption or safe memory management. On the other hand, PQC protocols are generally built and optimized in modern programming languages [48] such as Rust, Go, or C++, offering memory safety features, concurrency handling, and cryptographic libraries. Hence, integrating these algorithms into legacy systems may induce issues such as language incompatibility, runtime limitations [49], and the lack of compilers for secure cross-language integration. This represents real technical setbacks to the adoption of PQC in legacy environments.

2.8 Implications for Migration Strategy

For a successful PQC migration strategy [33] in legacy systems, cryptographic dependencies need to be identified, and cryptographic upgrades need to be planned and secured [29]. Also, performance limitations need to be quantified and factored into the broader risk analysis, ensuring realistic migration timelines and priorities [32]. This strategy needs also to account for cross-system compatibility, vendor coordination, and fallback mechanisms, in order to avoid service disruption. Potential regulatory requirements, such as certification timelines and jurisdictional requirements, reinforce the need for a risk framework that integrates compliance impacts [40]. More broadly, successful migration depends on a gradual and risk-informed dedicated approach, based on system-specific impact assessments and guided by a governance-aware methodology, that addresses not only technical threats, but also structural and organizational barriers that can delay or obstruct a timely response [22].

3 The Gaps in Current Approaches

Despite the increased awareness towards quantum cyber threats and the drive behind PQC standardization, current landscape of migration guidance and research displays many critical gaps, particularly regarding legacy environments. Most existing initiatives, either led by standardization bodies or academic researchers, concentrate on algorithmic design, protocol integration, and macro strategic planning. Therefore, they often fail to account for the operational realities, technical rigidity, and governance constraints specific to legacy systems. These gaps can be summarized across five key limitations:

3.1 Crypto-Focused Standards

Leading standardization initiatives such as the NIST PQC Program [50], ETSI ISG QSC[33], and ISO SC 27[51] are instrumental in advancing quantum-resistant protocols and promoting best practices for their integration. Their focus today is on the selection and specification of quantum-safe cryptographic primitives. However, these specifications are not generally tailored to outdated architectures or systems with low crypto-agility. Consequently, organizations with legacy environments are left without practical methodologies to secure the deployment of PQC in these critical scopes. The dedicated approach needed for PQC migration in legacy systems has to extend beyond cryptographic substitution and address the whole transition process with all its constraints.

3.2 Abstract Migration Guidelines

Many regulatory bodies and tech authorities published high-level migration strategies [52], often recommending inventorying assets, classifying cryptographic dependencies, and adopting hybrid models [15]. However, these guidelines remain too generic to be effective in complex technological environments. They tend to assume that the IT architectures concerned by the migration are modern and modular, without providing clear procedures to prioritize efforts, mitigate service disruption, or navigate regulatory recertification in sectors with critical infrastructures [49]. Legacy systems require granular, context-aware, and risk-driven migration roadmaps, which are currently lacking in most frameworks. The dedicated approach needed for PQC migration in legacy systems has to be grounded in operational reality, and provide practical and actionable guidance, instead of abstract recommendations.

3.3 Experimental Limitations

Much empirical work on the evaluation of PQC protocols has been conducted in controlled laboratory settings, focusing on performance benchmarking, bandwidth requirements, or cryptographic correctness [53]. Although informative, these experimentations rarely capture the integration friction, lifecycle constraints, or governance challenges typical of operational legacy systems [49]. As a result, their findings are not often transferable to production-grade environments where PQC must co-exist with outdated components, hard-coded protocols, and real-time availability requirements [54]. The dedicated approach needed for PQC migration in legacy systems has to be informed by real-life data and field experience to ensure relevance and applicability.

3.4 Limited Risk Frameworks

Recent academic initiatives made promising progress in developing risk-based approaches to PQC migration. These models are still in their early stages and often overlook the operational complexities of IT environments [43]. As a result, they offer valuable theoretical insights but fall short of providing actionable guidance for real-world deployments in resource-constrained rigid infrastructures. Most frameworks fail to account for sector-specific compliance obligations, interoperability risks, or the financial implications of cryptographic transformation [55]. Also, few propose practical decision-making tools, such as readiness indicators, system-specific risk scores, or migration playbooks, creating major disconnects between cryptographic innovation and secure operations. The dedicated approach needed for PQC migration in legacy systems has to integrate a comprehensive context-aware risk management framework to support informed prioritization and sustainable execution.

3.5 Legacy Systems as a Blind Spot

Despite being widely recognized by cybersecurity officials as one of the most difficult aspects of the transition, migrating legacy systems is still frequently overlooked in technical documentation, pilot initiatives, and policy frameworks. Their unique characteristics, whether architectural, regulatory, or organizational, demand targeted solutions that cannot simply be addressed through generic cryptographic transition models. Without a dedicated approach, legacy environments risk becoming the critical weak point in the post-quantum security chain.

Table 3 below offers a structured comparison of key standards and academic contributions related to post-quantum cryptography (PQC), evaluated against the five critical limitations identified earlier. Each publication is assessed based on whether it addresses the entire **Migration Process** (as opposed to focusing solely on cryptographic primitives - see 3.1), provides **Practical Guidance** (rather than abstract recommendations - see 3.2), draws on **Real-world Data** (as opposed to being limited to experimental or theoretical contexts - see 3.3), incorporates a **Full Risk Methodology** (rather than minimal or absent risk considerations - see 3.4), and explicitly addresses **Legacy Systems** constraints (as opposed to overlooking them entirely - see 3.5).

The publications selected for this comparative analysis were identified through a structured literature review, conducted across academic databases (including IEEE Xplore, ACM Digital Library, and arXiv) and repositories of major standardization bodies (NIST, ETSI, and ISO). Search terms combined post-quantum cryptography with migration, risk, legacy systems, and crypto-agility. Selection was guided by three criteria: (1) relevance to PQC migration planning or risk assessment, (2) influence within the field as reflected by citation impact or institutional authority, and (3) coverage of at least one of the five dimensions under evaluation. The resulting set includes both foundational references that shaped the field and more recent contributions representing the current state of research and standardization. While not exhaustive, this selection is representative of the current landscape of migration guidance and standardization, and captures the key limitations that motivate the framework proposed in this paper.

Reference	Migration Process	Practical Guidance	Real-world Data	Full Risk Methodology	Legacy Systems
NIST SP 1800-38	✓	✓	✗	✗	◐
ETSI TR 103 619	✓	✗	✗	✗	✗
ETSI TS 103 744	✓	✓	✗	✗	✗
ISO/IEC 27005:2022	✗	✓	✗	✓	◐
Chen et al. (2016)	✗	✗	✗	✗	✗
Heninger & Valenta (2017)	✗	✗	✗	✗	✗
Mosca et al. (2018)	✗	✗	✗	✗	✗
MITRE (2020)	✗	✗	✗	✗	✗
CARAF Ma et al. (2021)	◐	✓	◐	◐	✗
Cisco (2022)	✓	✓	✗	✗	✗
von Nethen et al. (2023)	✓	✓	✗	✗	✗
Baseri et al. (2024)	◐	✗	✗	✗	✗
Nather et al. (2024)	✓	◐	✗	✗	✗
Demir et al. (2025)	✗	✗	✓	✗	◐

Table 3: Gap-Analysis of PQC Standards and Research Papers

As illustrated in Table 3, existing publications do not fully cover all five dimensions. Standards like NIST SP 1800-38 [56], ETSI TS 103 744 [33], and Cisco (2022) [57] provide practical guidance but fall short in areas like real-world validation, formalized risk modeling, or clear treatment of legacy challenges. ISO 27005:2022 [58] offers a mature risk management framework, but remains generic and is not tailored to the specific challenges of PQC migration or legacy environments.

Articles like Chen et al. (2016) [59], Mosca (2018) [32], and Heninger & Valenta (2017) [60] remain influential for their strategic insights, but do not engage with real-world system challenges or migration planning. Recent academic publications such as von Nethen et al. (2023) [55] and Nather et al. (2024) [61] move toward structured migration processes, but provide only partial practical guidance and overlook risk governance and legacy-specific constraints.

CARAF [62] represents the closest existing work to a risk-based approach for cryptographic transition, offering practical tooling and partial risk estimation. However, its scope remains limited to crypto agility assessment and does not address the broader technical, operational, organizational, and regulatory risks specific to legacy environments, nor does it distinguish legacy systems as a category requiring dedicated treatment.

Baseri et al. (2024) [63] and Demir et al. (2025) [54] contribute valuable empirical insights into protocol vulnerabilities and real-world PQC performance respectively, but neither engages with migration planning, risk methodology, or the constraints of legacy infrastructures in any systematic way.

4 Position: The Need for a Field-Informed, Risk-Based Framework for PQC Migration in Legacy Systems

This position paper addresses the gaps illustrated in Table 3, proposing a comprehensive risk-based framework tailored to the constraints of legacy systems undergoing post-quantum cryptography (PQC) migration.

This framework is structured around three interdependent layers: a diagnostic assessment of legacy system nature and constraints, a qualitative risk assessment grounded in those constraints, and a quantitative ROI-based evaluation to support migration decision-making.

The following subsections present the key components of the proposed framework, which collectively form the foundation of a holistic, secure, scalable, and context-aware strategy for PQC migration in legacy environments.

4.1 Diagnostic characterization of legacy system constraints

A foundational element of the proposed methodology is a diagnostic assessment of legacy system nature and constraints, ensuring that the following risk models are grounded in real-life conditions rather than in abstract assumptions.

Unlike existing approaches that treat legacy as a generic label, this layer begins by understanding what makes each system legacy in its specific context before any risk assessment is applied.

This diagnostic layer is informed by an empirical survey conducted among large organizations across critical sectors. The survey captures field data on legacy system composition, cryptographic usage patterns, and migration constraints across diverse operational environments, providing the empirical foundation needed to identify and classify legacy systems according to a structured taxonomy aligned with recognized governance practices (e.g., ITIL [44], ITAM [64], CIS Controls [65]).

The resulting characterization translates the complexity of legacy environments into actionable insight by structuring them into a format that can feed directly into the qualitative and quantitative risk models that follow.

4.2 Qualitative Risk Models to Assess Legacy PQC Migration

The second core component of the proposed methodology is the elaboration of qualitative risk models dedicated to PQC migration in legacy systems that ensure that the migration strategy relies on strong risk management foundations while responding to the constraints of these systems (e.g., architectural rigidity, resource constraints, operational dependencies).

The proposed models need to be inspired by recognized risk frameworks such as ISO 31000 [66], ISO 27005 [58], NIST RMF [67], and STRIDE [64], to cover a wide range of risk categories (e.g., technical, operational, organizational, regulatory), capturing critical factors outside cryptographic vulnerabilities and service disruption (vendor lock-in, documentation gaps, system interoperability, recertification impacts).

In order for these models to reflect real-life behavior, a strong collaboration between cybersecurity, IT, and transversal functions is required, ensuring the alignment between the migration process and the technical and organizational realities of organizations.

4.3 Quantitative Risk Models to Evaluate Legacy PQC Migration

To ensure the holistic nature of the proposed framework, the third component introduces quantitative risk models [68] tailored to PQC migration in legacy systems. These models help organizations move beyond qualitative assessments by assigning measurable values to risk factors, allowing more objective data-driven decision making.

Inpired by established approaches such as FAIR [69] (Factor Analysis of Information Risk), the methodology quantifies a wide range of legacy-specific risks, such as performance degradation, resource constraints, upgrade costs, and downtime probabilities. It plays a key role in identifying systems in which the adoption of PQC can exceed technical limits or trigger significant operational and compliance burdens.

A key output of this quantitative layer is an ROI-based analysis of migration options, enabling organizations to evaluate the financial and operational trade-offs of each migration path, ensuring that decisions are not only technically justified, but also strategically and financially grounded [70]. When combined with qualitative insights and governance input, this layer ensures that PQC migration decisions translate into actionable, resource-aware roadmaps adapted to the realities of legacy infrastructures.

4.4 A Field-Informed, Risk-Based Framework for PQC Migration in Legacy Systems

The three layers presented above form the foundation of a unified, field-informed, risk-based framework tailored to the challenges of PQC migration in legacy systems. Together, they address the critical gaps identified in Table 3 and demonstrate full coverage across all five dimensions as shown in Table 4

This proposed framework supports the transition lifecycle, from initial asset identification and cryptographic scoping to effective migration planning. It differs from purely theoretical initiatives

by providing actionable tools that bridge high-level objectives and operational implementation while adapting to the architectural and governance realities of legacy infrastructures.

Hence, it addresses legacy-specific constraints (e.g., system rigidity, limited upgrade capacity, operational sensitivity, regulatory overhead) while offering a repeatable, organization-wide methodology for achieving secure, scalable, and governance-aligned PQC migration.

Dimensions	**This Proposition**	**Justifications**
Migration Process	✓	The proposed framework addresses the entire migration lifecycle, from system scoping to PQC implementation.
Practical Guidance	✓	The proposed framework provides actionable tools that support implementation in real operational contexts.
Real-World Data	✓	The proposed framework is based on empirical insights, ensuring relevance beyond theoretical assumptions.
Full Risk Methodology	✓	The proposed framework integrates both qualitative and quantitative risk models within a unified methodology.
Legacy Systems	✓	The proposed framework is specifically tailored to address the constraints of PQC migration in legacy systems.

Table 4: Coverage of Key Dimensions by the Proposed Framework

To achieve its full operational potential, the proposed framework should not be treated as a standalone or isolated process. In contrast, it must be fully integrated within existing enterprise risk management and PQC migration programs. Hence, its components must be designed to align with recognized standards, as well as established organizational processes and internal frameworks. Therefore, instead of becoming yet another competing standard, it would serve as a practical enabler, providing a structured, context-aware tool set that can be seamlessly embedded into ongoing post-quantum transition efforts without introducing unnecessary complexity.

5 Conclusion and Future Works

The transition to post-quantum cryptography (PQC) constitutes an important shift in digital security with long-term implications regarding cryptographic resilience, data protection, and critical infrastructure integrity. Standardization bodies made significant advances regarding quantum-resistant protocols selection and migration guidance elaboration. However, many practical challenges related to implementing these changes are not yet adequately addressed, especially in legacy systems. These environments frequently inflexible, resource-poor and strongly embedded in operational and regulatory processes require more specific attention.

This paper argued for a comprehensive risk-based framework, tailored to PQC migration in legacy systems. This suggested approach incorporates incorporates a diagnostic assessment of legacy system nature and challenges, qualitative and quantitative risk modeling, and migration planning within a holistic context-aware methodology. It intends to provide organizations with actionable, scalable tools to achieve cryptographic goals despite real-world constraints of architecture, governance, and sector-specific regulations.

The proposed position will be substantiated further though a dedicated research program that merges theoretical guidance with applied experimentation. Future work will produce risk models, validate prioritization criteria, and develop practical tools, that can support real-world implementation. These efforts will be supported by practical case studies within financial institutions and critical infrastructure operators, providing insight across diverse technical and organizational settings.

Finally, our continued engagement with standardization bodies and regulatory stakeholders will ensure that the framework evolves in accordance with emerging regulatory requirements and sector-specific expectations. The primary objective being the deliverance of a rigorous yet operationally grounded reference model for transitioning legacy environments into post-quantum readiness.

References

[1] SRI International. "New data on the growing quantum industry". In: (Apr. 2025). Private VC investment in quantum reached a record USD 2.6 billion in 2024; public funding estimated at USD 44.5 billion globally (China USD 15 billion, U.S. USD 7.7 billion, U.K. USD 4.3 billion). URL: https://www.sri.com/press/story/new-data-on-the-growing-quantum-industry/.

[2] U. H. Shaikh et al. "A Comparative Survey of Symmetric and Asymmetric Key Cryptography Algorithms". In: *Proceedings of the 2nd International Multidisciplinary Conference on Emerging Trends in Engineering Technology (2nd IMCEET-2024)*. Mehran University of Engineering and Technology, Oct. 2024, pp. 257–258.

[3] Ronald L Rivest, Adi Shamir, and Leonard Adleman. "A method for obtaining digital signatures and public-key cryptosystems". In: *Communications of the ACM* 21.2 (1978), pp. 120–126.

[4] National Institute of Standards and Technology. *Digital Signature Standard (DSS)*. Tech. rep. FIPS PUB 186-4. U.S. Department of Commerce, 2013. URL: https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.186-4.pdf.

[5] Taher ElGamal. "A public key cryptosystem and a signature scheme based on discrete logarithms". In: *IEEE Transactions on Information Theory* 31.4 (1985), pp. 469–472.

[6] Neal Koblitz. "Elliptic curve cryptosystems". In: *Mathematics of Computation* 48.177 (1987), pp. 203–209.

[7] P.W. Shor. "Algorithms for quantum computation: discrete logarithms and factoring". In: *Proceedings 35th Annual Symposium on Foundations of Computer Science*. 1994, pp. 124–134. DOI: 10.1109/SFCS.1994.365700.

[8] Lov K. Grover. "A fast quantum mechanical algorithm for database search". In: *Proceedings of the Twenty-Eighth Annual ACM Symposium on Theory of Computing*. STOC '96. Philadelphia, Pennsylvania, USA: Association for Computing Machinery, 1996, pp. 212–219. ISBN: 0897917855. DOI: 10.1145/237814.237866. URL: https://doi.org/10.1145/237814.237866.

[9] Joan Daemen and Vincent Rijmen. *The Design of Rijndael: AES—The Advanced Encryption Standard*. Springer, 2002. ISBN: 9783540425809.

[10] McKinsey & Company. *The Year of Quantum: From concept to reality in 2025*. Public investments reached USD10billion in early 2025 (e.g. Japan USD7.4billion, Spain USD0.9billion); 2024 government support for QT startups USD680million, total QT funding USD1.8billion. June 2025. URL: https://www.mckinsey.com/capabilities/mckinsey-digital/our-insights/the-year-of-quantum-from-concept-to-reality-in-2025.

[11] Anonymous. *How to factor 2048-bit RSA integers with less than a million noisy qubits*. Unpublished commentary or presentation. Discussion or summary based on follow-up work to Gidney and Ekerå (2021). 2024.

[12] National Institute of Standards and Technology. *Post-Quantum Cryptography Standardization*. https://csrc.nist.gov/projects/post-quantum-cryptography. Accessed: 2025-06-25. 2016–ongoing.

[13] ANSSI. *ANSSI Views on the Post-Quantum Cryptography Transition (2023 Follow-up)*. Follow-up to the January 2022 position paper. Dec. 2023. URL: https://cyber.gouv.fr/sites/default/files/document/follow_up_position_paper_on_post_quantum_cryptography.pdf (visited on 07/20/2025).

[14] Bundesamt für Sicherheit in der Informationstechnik (BSI). *Kryptographische Verfahren: Empfehlungen und Schlüssellängen (TR-02102)*. Technische Richtlinie. Includes guidance on post-quantum migration. BSI, Feb. 2024. URL: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.pdf (visited on 07/20/2025).

[15] NIS Cooperation Group. *A Coordinated Implementation Roadmap for the Transition to Post-Quantum Cryptography*. Published on the EU Digital Strategy portal. June 2025. URL: https://digital-strategy.ec.europa.eu/en/library/coordinated-implementation-roadmap-transition-post-quantum-cryptography (visited on 07/20/2025).

[16] Yemi Adeola and Eben Charles. "Addressing the Quantum Cybersecurity Challenge: The "HarvestNow,DecryptLater" Threat". In: *ResearchGate* (Mar. 2025). https://www.researchgate.net/publication/390175220_Addressing_the_Quantum_Cybersecurity_Challenge_The_Harvest_Now_Decrypt_Later_Threat, accessed 2025-06-23.

[17] Dustin Moody and Ray Perlner and Andrew Regenscheid and Angela Robinson and David Cooper. *Transition to Post-Quantum Cryptography Standards*. NIST Interagency Report NIST IR 8547 (Initial Public Draft). Describes NIST's phased approach and timelines (to 2035) for migrating from quantum-vulnerable algorithms to post-quantum key-establishment and signature schemes. National Institute of Standards and Technology, Nov. 2024. URL: https://csrc.nist.gov/pubs/ir/8547/ipd.

[18] William Barker, William Polk, and Murugiah Souppaya. *Getting Ready for Post-Quantum Cryptography: Exploring Challenges Associated with Adopting and Using Post-Quantum Cryptographic Algorithms*. Cybersecurity White Paper NIST CSWP 04282021. Introduces PQC adoption challenges—e.g., implementation effort, protocol modifications, crypto agility—post-standardization. National Institute of Standards and Technology (NIST), Apr. 2021. URL: https://doi.org/10.6028/NIST.CSWP.04282021.

[19] International Organization for Standardization, International Electrotechnical Commission, and Institute of Electrical and Electronics Engineers. *ISO/IEC/IEEE 12207:2017 – Systems and Software Engineering – Software Life Cycle Processes*. Available from: https://www.iso.org/standard/63712.html. 2017.

[20] Olufunmilayo Ogunwole et al. "Modernizing Legacy Systems: A Scalable Approach to Next-Generation Data Architectures and Seamless Integration". In: *International Journal of Multidisciplinary Research and Growth Evaluation* 4.1 (Apr. 2025). Accessed: 2025-06-23, pp. 901–909. DOI: 10.54660/.IJMRGE.2023.4.1.901-909.

[21] Scott R. Faulk and Gregg H. Gunsch. "Critical infrastructure protection: Ensuring legacy systems meet security requirements". In: *International Journal of Critical Infrastructure Protection* 3.3-4 (2010), pp. 144–150.

[22] Yan Tan et al. "Towards secure integration of legacy and modern systems in critical infrastructures". In: *2017 IEEE International Conference on Smart Computing (SMARTCOMP)*. IEEE. 2017, pp. 1–8. DOI: 10.1109/SMARTCOMP.2017.7956632.

[23] Johannes Sametinger et al. "Security challenges for medical devices". In: *Commun. ACM* 58.4 (Mar. 2015), pp. 74–82. ISSN: 0001-0782. DOI: 10.1145/2667218. URL: https://doi.org/10.1145/2667218.

[24] Inês Melo, Daniel Polónia, and Leonor Teixeira. "Human–AI Collaboration in the Modernization of COBOL-Based Legacy Systems: The Case of the Department of Government Efficiency (DOGE)". In: *Computers* 14.7 (2025). ISSN: 2073-431X. DOI: 10.3390/computers14070244. URL: https://www.mdpi.com/2073-431X/14/7/244.

[25] Nicola d'Ambrosio et al. "SCASS: Breaking into SCADA Systems Security". In: *Computers Security* 151 (2025), p. 104315. ISSN: 0167-4048. DOI: https://doi.org/10.1016/j.cose.2025.104315. URL: https://www.sciencedirect.com/science/article/pii/S0167404825000045.

[26] Sabrina Sicari et al. "Security, privacy and trust in Internet of Things: The road ahead". In: *Computer Networks* 76 (2015), pp. 146–164. DOI: 10.1016/j.comnet.2014.11.008.

[27] K. Moriarty, C. Celi, and S. Osborn d. *Recommendation for Stateful Hash-Based Signature Schemes*. Tech. rep. NIST SP 800-208. https://doi.org/10.6028/NIST.SP.800-208. National Institute of Standards and Technology, 2020.

[28] Elaine Barker and Quynh Dang. "Legacy system constraints and the case for crypto modernization". In: *IEEE Security & Privacy* 17.5 (2019), pp. 70–75.

[29] William Whyte et al. "Crypto-agility and interoperability challenges in post-quantum migration". In: *Communications of the ACM* 64.2 (2021), pp. 60–67.

[30] Elaine Barker. *Recommendation for cryptographic key management: Part 3 - Application-specific key management guidance*. Tech. rep. NIST Special Publication 800-57 Part 3 Rev. 1, 2020. URL: https://doi.org/10.6028/NIST.SP.800-57pt3r1.

[31] Panos Kampanakis. "Post-quantum cryptography: Challenges for deployment in standard protocols". In: *Proceedings of the 8th International Conference on Post-Quantum Cryptography (PQCrypto)*. Springer, 2014, pp. 79–96.

[32] Michele Mosca. "Cybersecurity in an era with quantum computers: Will we be ready?" In: *IEEE Security & Privacy* 16.5 (2018), pp. 38–41.

[33] *Quantum-Safe Cryptography (QSC); Quantum-Safe Migration Strategies*. Tech. rep. ETSI TS 103 744 V1.1.1. Developed by ETSI ISG QSC; includes guidance for quantum-safe migration in VPNs, TLS, 5G, and PKI environments. Accessed: 2025-06-23. European Telecommunications Standards Institute (ETSI), Nov. 2022. URL: https://www.etsi.org/deliver/etsi_ts/103700_103799/103744/01.01.01_60/ts_103744v010101p.pdf.

[34] Oded Regev. "On lattices, learning with errors, random linear codes, and cryptography". In: *Proceedings of the 37th Annual ACM Symposium on Theory of Computing (STOC)*. ACM, 2005, pp. 84–93. DOI: 10.1145/1060590.1060603. URL: https://doi.org/10.1145/1060590.1060603.

[35] Léo Ducas et al. "CRYSTALS-Kyber: A CCA-secure module-lattice-based KEM". In: *2019 IEEE European Symposium on Security and Privacy (EuroS&P)* (2019), pp. 353–367.

[36] MITRE Corporation. *Managing Legacy System Risks in Modern Environments*. https://www.mitre.org/publications/technical-papers/managing-legacy-system-risks-in-modern-environments. Accessed: 2025-06-25. 2020.

[37] National Institute of Standards and Technology (NIST). *Security Requirements for Cryptographic Modules*. FIPS Publication FIPS PUB 140-3. U.S. Department of Commerce, 2019. URL: https://doi.org/10.6028/NIST.FIPS.140-3.

[38] Common Criteria Recognition Arrangement (CCRA). *Common Criteria for Information Technology Security Evaluation (ISO/IEC 15408)*. https://www.commoncriteriaportal.org. Accessed: 2025-07-15. 2022.

[39] European Parliament and Council. *Regulation (EU) No 910/2014 on electronic identification and trust services for electronic transactions in the internal market (eIDAS)*. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32014R0910. Official Journal of the European Union, L 257, 28.8.2014. 2014.

[40] John Mattsson, Hasan Kahn, and Yeongjin Yoon. "Post-Quantum Cryptography in the Real World: Adoption Challenges and Transition Paths". In: *2021 IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA)*. IEEE. 2021, pp. 100–107. DOI: 10.1109/TPS-ISA52974.2021.00022.

[41] Martin R. Albrecht, Jannik Brendel, Debayan Ghosal, et al. "Hybrid Cryptography: The Transition to Post-Quantum Security". In: *ACM Computing Surveys* 56.3 (2023). DOI: 10.1145/3570941.

[42] Kevin H. Bennett and Vaclav T. Rajlich. "Legacy information systems: Issues and directions". In: *IEEE Software* 16.5 (2000), pp. 103–111.

[43] Yaser Baseri, Vikas Chouhan, and Abdelhakim Senhaji Hafid. "Navigating Quantum Security Risks in Networked Environments: A Comprehensive Study of Quantum-Safe Network Protocols". In: *Computers & Security* (Apr. 2024). Preprint; analyzed vulnerabilities across TLS, IPsec, SSH, PGP; accessed: 2025-06-23. DOI: 10.2139/ssrn.4687851.

[44] AXELOS. *ITIL Foundation: ITIL 4 Edition*. Official guide to the ITIL 4 framework, covering service management principles including value, processes, and practices. London: TSO (The Stationery Office), 2019. ISBN: 9780113316076.

[45] International Organization for Standardization. *ISO/IEC 20000-1:2018 - Information technology – Service management – Part 1: Service management system requirements*. https://www.iso.org/standard/70636.html. International standard defining requirements for an IT service management system, including lifecycle planning, delivery, and improvement. 2018.

[46] International Electrotechnical Commission. *IEC 62402:2019 – Obsolescence Management – Application Guide*. https://webstore.iec.ch/publication/63159. International standard providing best practices for managing obsolescence throughout the system or product lifecycle. 2019.

[47] Cigref. *Pilotage de la dette et de l'obsolescence IT : Préserver l'agilité, la sécurité et la capacité d'innovation des SI*. Tech. rep. Report on IT debt governance, obsolescence management, and lifecycle best practices. Cigref, May 2021. URL: https://www.cigref.fr/wp/wp-content/uploads/2021/05/Cigref-Rapport-Pilotage-Dette-Obsolescence-IT-Mai-2021.pdf.

[48] National Institute of Standards and Technology (NIST). *Post-Quantum Cryptography Standardization – Round 3 Submissions*. Most algorithm implementations provided in C/C++ and Rust. 2020. URL: https://csrc.nist.gov/Projects/post-quantum-cryptography/round-3-submissions.

[49] Christian Näther et al. "Migrating Software Systems Toward Post-Quantum Cryptography-A Systematic Literature Review". In: *IEEE Access* 12 (2024), pp. 132107–132126. ISSN: 2169-3536. DOI: 10.1109/access.2024.3450306. URL: http://dx.doi.org/10.1109/ACCESS.2024.3450306.

[50] National Institute of Standards and Technology. *Status Report on the Fourth Round of the NIST Post-Quantum Cryptography Standardization Process*. NIST Interagency/Internal Report IR 8545. Final report, available from the NIST PQC publications page. U.S. Department of Commerce, Mar. 2025.

[51] *Information Security — Digital Signatures with Appendix — Part 4: Post-Quantum Signature Mechanisms*. Developed by ISO/IEC JTC 1/SC 27; focuses on interoperability, algorithm agility, and long-term PQC deployment. Accessed: 2025-06-23. 2022.

[52] Joseph Albanese et al. *Migration to Post-Quantum Cryptography*. https://csrc.nist.gov/publications/detail/white-paper/2023/11/07/migration-to-post-quantum-cryptography/final. NIST White Paper on migration planning and cryptographic inventories. 2024.

[53] ETSI Industry Specification Group (ISG) Quantum Safe Cryptography. *Quantum-Safe Cryptography and Security: An Introduction, Benefits, Enablers and Challenges*. Tech. rep. ETSI TR 103 619 V1.1.1. European Telecommunications Standards Institute (ETSI), 2020. URL: https://www.etsi.org/deliver/etsi_tr/103600_103699/103619/01.01.01_60/tr_103619v010101p.pdf.

[54] Elif Dicle Demir, Buse Bilgin, and Mehmet Cengiz Onbasli. "Performance Analysis and Industry Deployment of Post-Quantum Cryptography Algorithms". In: *arXiv preprint arXiv:2503.12952* (2025). Highlights legacy-system integration challenges in telecom environments.

[55] Nils von Nethen et al. "PMMP – PQC Migration Management Process". In: *arXiv preprint arXiv:2301.04491* (2023). Proposes a risk-based management process, but evaluated only theoretically without practical deployment insights.

[56] David Cooper et al. *Migration to Post-Quantum Cryptography*. NIST Special Publication 1800-38A. Accessed: 2025-06-23. Final PQC standards are expected in 2025, complementing already published documentation on PQC migration strategies, implementation guidance, and related specifications. National Institute of Standards and Technology (NIST), Aug. 2023. URL: https://csrc.nist.gov/publications/detail/sp/1800-38/ga.

[57] Cisco Systems. *Post-Quantum Cryptography Readiness: A Business Guide to Managing the Quantum Threat*. https://www.cisco.com/c/en/us/about/security-center/post-quantum-crypto.html. Accessed: 2025-06-25. 2022.

[58] International Organization for Standardization. *Information Security, Cybersecurity and Privacy Protection — Guidance on Managing Information Security Risks*. Provides guidance for information security risk management in support of ISO/IEC 27001. 2022. URL: https://www.iso.org/standard/80585.html.

[59] Lidong Chen et al. *Report on Post-Quantum Cryptography*. NIST Interagency/Internal Report (NISTIR) 8105. Accessed: 2025-06-23. National Institute of Standards and Technology (NIST), Apr. 2016. DOI: 10.6028/NIST.IR.8105.

[60] Nadia Heninger and Luke Valenta. "A Survey on Post-quantum Key Exchange Protocols". In: *Proceedings of the 2017 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, 2017, pp. 289–304. DOI: 10.1109/EuroSP.2017.37.

[61] Christian Näther et al. "Migrating Software Systems towards Post-Quantum Cryptography – A Systematic Literature Review". In: *arXiv preprint arXiv:2404.12854* (2024). Identifies high implementation effort, fragmented tools, and low transferability of lab results.

[62] Chujiao Ma et al. "CARAF: Crypto Agility Risk Assessment Framework". In: *Journal of Cybersecurity* 7.1 (2021), tyab013. DOI: 10.1093/cybsec/tyab013.

[63] Yaser Baseri, Vikas Chouhan, and Abdelhakim Senhaji Hafid. "Evaluation Framework for Quantum Security Risk Assessment: A Comprehensive Strategy for Quantum-Safe Transition". In: *Computers & Security* (2024). Preprint. DOI: 10.2139/ssrn.4687851. URL: https://doi.org/10.2139/ssrn.4687851.

[64] *Information technology – IT asset management – Part 1: IT asset management systems – Requirements*. 2017.

[65] Center for Internet Security. *CIS Controls v8*. 2021. URL: https://www.cisecurity.org/controls/v8.

[66] *Risk Management — Guidelines*. Provides principles, framework, and process for risk management applicable to any organization. Accessed: 2025-06-23. Feb. 2018.

[67] Joint Task Force Transformation Initiative. *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy*. Tech. rep. NIST Special Publication 800-37 Revision 2. Defines NIST RMF including steps: Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor. National Institute of Standards and Technology (NIST), Dec. 2018. DOI: 10.6028/NIST.SP.800-37r2. URL: https://csrc.nist.gov/publications/detail/sp/800-37/rev-2/final.

[68] Alexander J. McNeil, Rüdiger Frey, and Paul Embrechts. *Quantitative Risk Management: Concepts, Techniques and Tools*. Revised. Princeton University Press, 2015. ISBN: 9780691166278.

[69] FAIR Institute. *FAIR: Factor Analysis of Information Risk*. 2022. URL: https://www.fairinstitute.org/.

[70] Douglas W. Hubbard. *The Failure of Risk Management: Why It's Broken and How to Fix It*. Wiley, 2020. ISBN: 9781119522034.